

Setting Up OpenAM for Web Authentication

OpenAM provides a system for integrating diverse Web applications—to share common authentication and authorisation systems. It can protect applications running on any Web or application server. With a centralised login for all applications, users need to log in only once on the OpenAM server to access any application. OpenAM also provides URL-based authorisation support on the protected resource.



OpenAM was originally known as openSSO when Sun Microsystems owned this open source project. Once Oracle decided to stop its support for openSSO, Forgerock (<http://forgerock.com/>) took over the code and started supporting it.

OpenAM is very easy to set up and manage. It provides cross-platform support. It just needs a Tomcat server to run the OpenAM server. OpenAM provides policy agents, which run along with the application or Web server. Policy agents protect the resources on the server based on the policy defined in the server. OpenAM provides support for keeping user information in a separate data store like Active Directory. The key benefit is that you get an authentication and authorisation system for free.

Initial login process

1. The browser sends a request to a protected resource for the first time without an SSO token.
2. The agent running on the Web server intercepts the request, and redirects it to the OpenAM server for authentication.
3. The OpenAM server performs authentication and sends back the SSO token to the agent.
4. The agent validates the token and allows access to the protected resource, based on the authorisation rules.

Subsequent access

1. The browser sends a request to another protected resource with the SSO token.
2. The agent validates the token with the OpenAM server,